COBRA7 | SAMPLE REPORT

تقرير اختبار اختراق نموذجي

مثال كامل على تقرير احترافي (بيانات خيالية)

تقرير نموذجي للتعلّم: الموقع والبيانات هنا خيالية بالكامل (متجر تدريبي اسمه Demo Shop)، والهدف تشوف شكل التقرير الاحترافي.

الملخص التنفيذي

اتفحص تطبيق متجر إلكتروني تدريبي بتصريح كتابي. اتكتشفت 5 نتائج: ثغرتين بخطورة عالية، وواحدة متوسطة، وواحدة منخفضة، وملاحظة معلوماتية. أخطر نتيجتين بتسمحوا بالوصول لبيانات العملاء، ومطلوب إصلاحهم قبل أي إطلاق فعلي.

النطاق والمنهجية

داخل النطاق: demo-shop.example (بيئة تدريب). **المنهج:** فحص يدوي حسب قائمة OWASP، بدون أي هجمات حجب خدمة.

ملخص النتائج

الرقم	العنوان	الخطورة
F-01	SQL Injection في خانة البحث	عالية
F-02	IDOR في عرض الطلبات	عالية
F-03	Stored XSS في تعليقات المنتجات	متوسطة
F-04	غياب Security Headers	منخفضة
F-05	رسائل خطأ مفصلة	معلوماتية

تفاصيل النتائج

F-01 — SQL Injection في خانة البحث عالية

المكان: `/search?q=`

الوصف: الـ Parameter q بيدخل في استعلام SQL من غير معالجة. كتابة ' OR '1'='1 رجّعت كل المنتجات بدل نتيجة البحث.

الأثر: قراءة بيانات من قاعدة البيانات، وفي حالات أسوأ تعديلها.

إعادة الإنتاج: 1) افتح /search. 2) اكتب ' OR '1'='1 في الخانة. 3) لاحظ ظهور كل المنتجات.

التوصية: استخدم Parameterized Queries في كل الاستعلامات، وافحص المدخلات.

F-02 — IDOR في عرض الطلبات عالية

المكان: `/api/orders/{id}`

الوصف: تغيير رقم الطلب في الرابط بيعرض طلب مستخدم تاني لأن السيرفر مش بيتحقق إن الطلب بتاع صاحب الجلسة.

الأثر: كشف بيانات عملاء آخرين (أسماء وعناوين).

إعادة الإنتاج: 1) سجّل دخول بحساب A. 2) افتح طلبك /api/orders/101. 3) غيّر الرقم لـ 102 وشوف طلب حساب B.

التوصية: تحقق إن الطلب يخص المستخدم الحالي في كل طلب على السيرفر.

F-03 — Stored XSS في تعليقات المنتجات متوسطة

المكان: `/product/7 (التعليقات)`

الوصف: التعليق بيتعرض في الصفحة من غير ترميز، فأي كود HTML/JS بيتنفّذ عند كل زائر.

الأثر: سرقة جلسات أو تنفيذ أفعال باسم الزائر.

إعادة الإنتاج: 1) اكتب تعليق فيه وسم script بسيط للتجربة. 2) افتح الصفحة من متصفح تاني وشوف إنه اتنفّذ.

التوصية: رمّز المخرجات (Output Encoding)، وأضف سياسة CSP.

F-04 — غياب Security Headers منخفضة

المكان: `كل الصفحات`

الوصف: الردود مفيهاش CSP أو X-Frame-Options أو HSTS.

الأثر: بيسهّل هجمات مثل Clickjacking وبيضعف الحماية العامة.

إعادة الإنتاج: فحص Headers الردود بأداة المتصفح.

التوصية: أضف الـHeaders الأساسية في إعدادات السيرفر.

F-05 — رسائل خطأ مفصلة معلوماتية

المكان: `/api/*`

الوصف: أخطاء السيرفر بتعرض Stack Trace بأسماء ملفات ومكتبات.

الأثر: بتساعد المهاجم يعرف تفاصيل داخلية.

إعادة الإنتاج: إرسال طلب غير صالح لأي Endpoint.

التوصية: اعرض رسالة عامة للمستخدم، وسجّل التفاصيل في اللوج فقط.

التوصيات حسب الأولوية

- [ ] إصلاح F-01 وF-02 فورًا قبل أي إطلاق.
- [ ] إصلاح F-03 خلال الدورة القادمة.
- [ ] تطبيق F-04 وF-05 ضمن تحسينات الإعدادات.
- [ ] إعادة الفحص بعد الإصلاح للتأكد.

تنبيه قانوني: المحتوى ده للتعليم والعمل المصرّح بيه فقط. اختبار أو فحص أنظمة مش بتملكها من غير تصريح كتابي صريح مخالف للقانون.